

Vulnerability Assessment & Penetration Testing Procedure


Standard Operating Procedure: VA&PT
Standard Operating Procedure for Vulnerability Assessment & Penetration Testing

Version	1.5
Effective Date	07/07/2025
Compiled by	Mayur Patekar
Reviewed by	Sumit Rangari
Approved by	Nikhil Bhujade (CISO)

Revision and Version Control:

Version	Date	Reason for Revision/Update	Created/Updated By	Reviewed By	Approved By
1.1	28-06-2021	First Copy	Hiten Kumar	Nikhil Bhujade	CISO
1.2	05-12-2022	Reviewed – No Change	Hiten Kumar	Nikhil Bhujade	CISO
1.3	09-02-2024	Control added as per the process	Hiten Kumar	Sumit Rangari	CISO
1.4	03-07-2024	Added section 3.1.1-10	Mandar Joshi	CISO	CRO
1.5	07-07-2025	Added section 11 & 12	Mayur Patekar	Sumit Rangari	CISO

**Standard Operating Procedure: VA&PT**

Contents

1. Purpose	4
2. Scope:.....	4
3. Procedure Statement	4
4. Responsibilities	5
5. Periodicity	5
6. Conduct Vulnerability Assessment Scan and Penetration Testing:	5
7. Configuration Compliance Review/ Baseline Assessment:	8
8. VAPT Assessment Approach:	9
9. Closure Timelines for Production Environment.....	11
10. Closure Timelines for Non-Production Environment.....	12
11. VAPT Timeline.....	12
12. Vulnerability understanding and Rescan	14
13. Points Considered for VA/PT	14
14. References.....	14
15. Abbreviation	15
16. Review:	15



Standard Operating Procedure: VA&PT

1. Purpose

The process describes in detail the vulnerability assessment and penetration testing activities followed at Poonawalla Fincorp. The purpose of Vulnerability assessment and penetration testing is to identify and mitigate vulnerabilities as per agreed frequency and minimize further exposure to security threats.

2. Scope:

The purpose of this procedure is to improve the security posture and mitigate the threat of security related vulnerabilities in Poonawalla Fincorp. This procedure defines the controls and steps that are required for identifying security vulnerabilities and ensuring reasonable level of security for the infrastructure and application levels.

3. Procedure Statement

This procedure defines the steps for performing vulnerability assessment and penetration testing in Poonawalla Fincorp environment. Vulnerability assessments and penetration testing will help identify security vulnerabilities, assess their threat levels, and reduce the associated risks. This procedure ensures that Poonawalla Fincorp's business information remains secure from external threats, with vulnerabilities mitigated promptly to enhance the overall information security posture.

Vulnerability Assessment:

It is conducted to identify weaknesses and security concerns in computer networks, systems, hardware, servers, and other parts of the IT infrastructure. It is a systematic review of security weaknesses in an information system.

Penetration Testing:

It is carried out to uncover vulnerabilities, threats, and risks that an attacker could exploit in applications, networks, API, hosted on PFL environment. It is a systematic review of security weaknesses in an information system.

Baseline Assessment:

Baseline Assessment/Configuration Review is a detailed review and verification of configuration settings of IT infrastructure components including systems, network devices & applications to measure the security effectiveness/ hardening of the infrastructure.



Standard Operating Procedure: VA&PT

4. Responsibilities

- Vulnerability Assessment & Penetration Testing is the responsibility of the Infosec team. It shall be conducted internally by the Infosec Team or by Third party vendors (Cert-In Empaneled) under Infosec supervision.
- For SaaS/PaaS/IaaS, SOC1/SOC2 and VAPT report shall be provided by vendor.

5. Periodicity

Security Assessment	Scope	Periodicity
Vulnerability Assessment	Servers and Networks Devices	Quarterly
	Laptops/Desktops (Sample Basis Assessment shall be performed)	Quarterly
	Databases	Half-yearly
Vulnerability Assessment & Penetration Testing	Applications (web & mobile) and Networks Devices	Annually
API Assessment	New API or any change in API	As per requirement
Red Teaming Assessment	Red Teaming Assessment	Annually
Configuration Review / Baseline Assessment	Servers and Networks Devices	Annually

6. Conduct Vulnerability Assessment Scan and Penetration Testing:

Sr. No	Activity	Process Steps	Owner
1	Identify and confirm asset inventory	Infosec team shall connect with IT Infra and IT application team and obtain list of classified assets, live and running hosts along with relevant IPs/subnet details of following Poonawalla Fincorp managed devices, & obtain prerequisite access for authenticated assessment. 1. Network devices, 2. Domain and IT server, 3. Database servers, 4. Application Servers, 5. Appliances, and 6. Laptop/Desktop	IT Team
2	Schedule/Plan VAPT scan	Vulnerability Assessment: VA scan shall be scheduled as per defined periodicity for Poonawalla Fincorp Managed assets that include	Infosec Team

Standard Operating Procedure: VA&PT

		servers, databases, network devices and laptops/desktops. - Based on asset type, VA scans shall be performed for assets as per scheduled calendar defined. Penetration Testing: Penetration Testing is scheduled for the below mentioned Poonawalla Fincorp managed devices: - Web application & APIs - Network Devices - Mobile application Note: Perform penetration testing on annual basis and/or upon significant development/change in IT Infrastructure	
3	Notification to stakeholders	Once testing is scheduled, an advance notification is sent to stake holder via email about the planned activity Vulnerability Assessment: - These scans are always scheduled in lean office hours/non-peak office hours or as per the management decision to minimize business disruption. - Scanning should always be done when availability of systems is high or as per management decision. Penetration Testing: - Penetration Testing is always scheduled in lean office hours/non-peak office hours or as per management decision to minimize business disruption.	Infosec Team
4	Performing VA scan/ Penetration testing	Vulnerability Assessment: - VA scan is performed on identified assets using VA tool/technology and reports are generated. - Scan can be performed by Internal VA team or third party as per management decision. Penetration Testing: - Penetration Testing is performed on identified Poonawalla Fincorp Managed Devices by third party/Vendor and reports are generated. - Infosec team is responsible to drive the activity.	Infosec Team
5	Report generation	Vulnerability Assessment: Based on the VA scans, below mentioned reports are generated by Information security team and are discussed during the governance meeting with respective stake holders. Monthly & Quartey VA report Penetration Testing: Based on the Penetration Testing, below mentioned reports are generated by Infosec Team	Infosec Team, IT Team, Application Owners

Standard Operating Procedure: VA&PT

		• Greybox/Blackbox/Whitebox testing for applications and infrastructure • Mobile application testing (Android and IOS) • API testing The output of the PT assessment is a report that provides a snapshot of all the identified vulnerabilities (POCs - proof of concept). These reports contain the prioritized list of vulnerabilities, vulnerability description, calculated risk, and remediation activities. These reports shall be published to management along with respective application and infrastructure owner. Mitigation plan shall be provided against all the open risk by risk owner to Infosec team. Risk Owner shall patch the identified risk of Critical, High, Medium, and Low category within timeline as defined in section "6 (Closure Timelines)".	
6	Remediation on UAT	Based on the VA/PT report, Risk Owner shall coordinate with respective stakeholders to close the identified findings. Infosec approval shall be given after closure of all the open risk or having proper justification and business approval on the open risks (if any). Change Management Process shall be followed.	IT Team, Application Owners
7	Remediation on Production	Upon successful remediation on UAT, provide the approvals for making the changes to the production environment. Same UAT configuration shall be maintained while moving the changes in production environment.	Infosec Team, IT Team, Application Owners
8	Rescan	Rescan/retesting shall be conducted for VA/PT observation to verify the actual closures.	Infosec Team
9	Exception management	• Application Owner / portfolio owner shall report to Information security team on vulnerabilities which cannot be closed along with reason and opt for exception. • False positive findings shall be closed based on closure evidence along with justification. • For critical, high, medium and low findings, which are not feasible to be remediated, shall go through an exception process and management approvals. • Exceptions for deviations from defined compliance requirements may be granted based on the risk assessment and business impact. • In case of no proper mitigation control to exceptions (Security concerns which cannot be controlled), Risk owners should apply for RAF document and get it approved from Poonawalla Fincorp management. • For RAF approval, Risk owner should follow Risk acceptance process.	Application / Owner, Infosec Team

Standard Operating Procedure: VA&PT

10	Retesting	- Upon successful patching on production environment, initiate retesting. - Perform the retesting and verify the closures of identified vulnerabilities. - Share the retesting report with the status of findings-closed/ open with system team. - The number of revalidation rounds will be limited to 3. After 3rd revalidation, CISO & Functional head approval will be required to perform furthermore revalidations.	Infosec Team/ Third Party Vendor (VA Team)
----	-----------	---	--

7. Configuration Compliance Review/ Baseline Assessment:

Sr. No	Activity	Process Steps	Owner
1	Identify and confirm asset inventory	Infosec team shall connect with IT team and obtain list of assets, live and running hosts along with relevant IPs/subnet details of following Poonawalla Fincorp managed devices& obtain prerequisite access for authenticated assessment/offline configuration assessment. 1. Network devices, 2. Domain and IT server, 3. Database servers, 4. Application Servers, 5. Appliances, and 6. Laptops/Desktops	IT Team
2	Scheduling Configuration compliance scan	Configuration compliance scans are performed on an annual basis and as per the Information Technology Security Policy document. The Poonawalla Fincorp managed devices/assets shall be covered in scope, which is as follows: • Operating system (Desktop/ Servers) • Network Devices • Active Directory • Firewall assurance solutions • Network architecture review for new infrastructure, new design, application if any All the configuration reviews are done based on “Minimum Security Baseline Guidelines” These scans are always scheduled in lean office hours/non-peak office hours or as per the management decision to minimize business disruption. Baseline security assessment shall be carried out in two phases: • While onboarding of new devices	Infosec Team

Standard Operating Procedure: VA&PT

		Ongoing review for existing devices on annual basis	
3	Notification to stakeholders	Advance notification is sent to the stake holders based on the planned reviews.	Infosec Team
4	Perform the scans and reviews	Initiate the scans and reviews as per the schedule	Infosec Team
5	Report generation	Based on the scans and the reviews reports are generated and are shared with the respective team Compliance Scan Report The output of the configuration review is a report that provides a snapshot of all misconfigurations and deviations observed against the defined Minimum-Security Baselines. These reports are shared with the IT Infrastructure team and application owners. Infosec team shall communicate all compliance review findings with respective risk owner and obtain the mitigation response. Risk Owner shall patch the identified risk of High, Medium, and Low category within timeline as defined in section "6 (Closure Timelines)".	Infosec Team
6	Remediation on UAT	Coordinate with respective stakeholders /teams to close the identified discrepancies to meet the compliance requirements.	Infosec Team/ IT Team
7	Remediation on Production	Upon successful remediation on UAT, provide the approvals for making the changes to the production environment.	IT Team
8	Exception management	Exceptions for deviations from defined compliance requirements shall be granted based on the risk assessment and business impact. These exceptions are reviewed to identify potential risk, business impact and the need for the approved exceptions. In case of no proper mitigation control to exceptions (Security concerns which cannot be controlled), Risk owners should apply for RAF document and get it approved from Poonawalla Fincorp management. For RAF approval, Risk owner should follow Risk acceptance process.	Infosec Team, IT Team

8. VAPT Assessment Approach:

Sr. No	Activity	Process Steps	Owner
1	Assessment Scope	Infosec team shall connect with IT Infra/IT Application/Business team to obtain prerequisite to commence the Application Security Assessment (Grey Box or Black Box)	Infosec Team

Standard Operating Procedure: VA&PT

		• The Verification Scope includes all code that was developed or modified in order to create the application • Scanning consists of using automated tools to access application interfaces, while the application is running, in order to detect vulnerabilities in the application's security controls • Business applications managed by Poonawalla Fincorp are required to undergo testing once in a year • Applications which are not scanned for more than 6 months must be reported to CISO (if any).	
2	Assessment practice	Reference for security assessment testing shall be taken from OWASP top 10 and SANS top 25. Below are the techniques used but not limited to this for security assessment: • Security Architecture Documentation Requirements ○ Verify that all application components (either individual or groups of source files, libraries, and/or executables) that are present in the application are identified. • Authentication Verification Requirements ○ Verify that all pages and resources require authentication except those specifically intended to be public. ○ Verify that all password fields do not echo the user's password when it is entered. ○ Verify that if a maximum number of authentication attempts are exceeded, the account is locked in a period of time. • Session Management Verification Requirements ○ Verify that the framework's default session management control implementation is used by the application. ○ Verify that sessions are invalidated when the user logs out. ○ Verify that session's time out after a specified period of inactivity. ○ Verify that all pages that require authentication to access them, have logout links. • Access Control Verification Requirements ○ Verify that users can only access protected functions for which they possess specific authorization. ○ Verify that users can only access URLs for which they possess specific Authorization. ○ Verify that users can only access data files for which they possess specific authorization.	Infosec Team

Standard Operating Procedure: VA&PT

		○ Verify that direct object references are protected, such that only authorized objects are accessible to each user. ○ Verify that directory browsing is disabled unless deliberately desired. ○ Verify that the framework's default session management control implementation is used by the application. • Input Validation Verification Requirements ○ Verify that the runtime environment is not susceptible to buffer overflows, or that security controls prevent buffer overflows. ○ Verify that a positive validation pattern is defined and applied to all input. ○ Verify that all input validation failures result in input rejection or input sanitization. • Error Handling and Logging Verification Requirements ○ Verify that the application does not output error messages or stack traces containing sensitive data that could assist an attacker, including session id and personal information. • Data Protection Verification Requirements ○ Verify that all forms containing sensitive information have disabled client-side caching, including auto-complete features. • Communication Security Verification Requirements ○ Verify that a path can be built from a trusted CA to each Transport Layer Security (TLS) server certificate, and that each server certificate is valid. • HTTP Security Verification Requirements ○ Verify that redirects do not include un-validated data. ○ Verify that the application accepts only a defined set of HTTP request methods, such as GET and POST. ○ Verify that every HTTP response contains a content type header specifying a safe character set (e.g., UTF-8, X-frame-options, and Cache-Control). ○ Verify that sensitive information does not reveal in the HTTP response body.	
--	--	--	--

9. Closure Timelines for Production Environment

Security Assessment	Scope	Closure Timeline (Days)
Vulnerability Assessment	Servers, networks, and servers which are exposed to internet (irrespective of any environment)	- Critical: 07 - High: 15 - Medium: 45



Standard Operating Procedure: VA&PT

Vulnerability Assessment	Vulnerability assessment for database	- Critical: 07 - High: 15 - Medium: 45
Baseline Assessment	All Servers & Network Devices (IT Infrastructure)	- Non- Compliance: 45
Penetration Testing (Blackbox/Gray box/Whitebox)	Applications and Network Devices	- Critical: 07 - High: 15 - Medium: 30 - Low: 45
Red Teaming Assessment	IT Applications and Infrastructures	- Critical: 07 - High: 15 - Medium: 30 - Low: 45
API Assessment	Application Programming Interface	- Critical: 07 - High: 15 - Medium: 30 - Low: 45

10. Closure Timelines for Non-Production Environment

Security Assessment	Scope	Closure Timeline (Days)
Vulnerability Assessment	Servers and network devices	- Critical: 15 - High: 30 - Medium: 60
Vulnerability Assessment	Databases	- Critical: 15 - High: 30 - Medium: 60
Vulnerability Assessment	Laptops/desktop assessment (sample basis)	- Critical: 15 - High: 30 - Medium: 60

11. VAPT Timeline

Test plan document: The scope, objectives, and approach of the test endeavor are all outlined in the test plan.

Test suite: Test cases require test data, expected output, and pass/fail criteria.

Test design and environment specifications: The test environment outlines the software configurations used for testing.

Note that the VAPT process is designed to be **adaptive and responsive** to business priorities. Activities are scheduled and executed based on application readiness, stakeholder availability, and operational considerations. This ensures that security assessments are both thorough and aligned with organizational needs.



Standard Operating Procedure: VA&PT

Test Planning

- **Approach Document:** The testing team prepares a document outlining the scope, objectives, and methodology for the VAPT activity. This includes understanding the application's architecture, data flow, and identifying critical components.
- **Initial Walkthrough:** A collaborative session is conducted with stakeholders to gain insights into the application's modules, integrations, and business logic.
- **Test Data Preparation:** The application team provides necessary test data, expected outputs, and access credentials to facilitate accurate and effective testing.

Testing Execution

- **Automated Scanning:** Vulnerability scans are performed using approved tools. The duration and depth of scanning may vary depending on the application's complexity and responsiveness.
- **Manual Testing:** Manual assessments are conducted in alignment with OWASP Top 10 and CERT-IN guidelines. This includes testing for business logic flaws, input validation, authentication, session management, and other critical security controls.
- **Environment Specifications:** Testing is carried out in a controlled environment that closely mirrors production to ensure the reliability of findings.

Observation Validation

- Findings from both automated and manual testing are reviewed and validated.
- Observations are reverified to eliminate false positives and confirm true positives.
- The testing team may engage with developers or application owners for clarification or additional context where needed.

Reporting

- All validated vulnerabilities are documented with detailed descriptions, impact analysis, screenshots, and proof-of-concept (POC) evidence.
- Remediation guidance is provided, tailored to the application's technology stack and business context.
- Reports are compiled using the designated reporting tool to ensure consistency, traceability, and ease of review.



Standard Operating Procedure: VA&PT

12. Vulnerability understanding and Rescan

- Rescans are conducted to verify the closure of previously reported vulnerabilities.
- Rescan requests should be initiated only after remediation efforts are completed and verified internally by the application team.

Each rescan must be supported with:

- a) Evidence of remediation (e.g., updated code, configuration changes, patch details).
- b) Updated test data and access credentials, if applicable.
- The rescan process includes validation of previously reported issues to confirm their resolution and to identify any residual or new vulnerabilities.
- The rescan process involves validating previously reported issues to confirm their resolution and to identify any residual or newly introduced vulnerabilities.
- While the team supports revalidation efforts, stakeholders are encouraged to consolidate fixes and request rescans only when confident that remediation is complete. This ensures optimal use of resources and timely closure of assessments.

13. Points Considered for VA/PT

- For critical information systems and/ or those in the De-Militarized Zone (DMZ) having customer interface, VA shall be conducted at least once every six months and PT at least once in 12 months. Also, PFL shall conduct VA/ PT of such information systems throughout their lifecycle (pre-implementation, post implementation, after major changes, etc.).
- For non-critical information systems, a risk-based approach shall be adopted to decide the requirement and periodicity of conduct of VA/ PT.
- VA/ PT shall be conducted by appropriately trained and independent information security experts/ auditors.
- In the post implementation (of IT project/ system upgrade, etc.) scenario, the VA/ PT shall be performed on the production environment. Under unavoidable circumstances, if the PT is conducted in test environment, PFL shall ensure that the version and configuration of the test environment resembles the production environment. Any deviation should be documented and approved by the Information Security Committee.
- PFL shall ensure to fix the identified vulnerabilities and associated risks in a time bound manner by undertaking requisite corrective measures and ensure that the compliance is sustained to avoid recurrence of known vulnerabilities such as those available in Common Vulnerabilities and Exposures (CVE) database.
- PFL shall put in place a documented approach for conduct of VA/ PT covering the scope, coverage, vulnerability scoring mechanism (e.g., Common Vulnerability Scoring System) and all other aspects. This may also apply to the RE's information systems hosted in a cloud environment.

14. References

- A.12.6 Technical Vulnerability Management



Standard Operating Procedure: VA&PT

- Master Direction – RBI IT Framework for NBFC Sector

15. Abbreviation

Abbreviation	Description
R	Responsible
A	Accountable
C	Consulted
I	Informed
Infosec	Information Security
IT	Information Technology
API	Application Programming Interface
VAPT	Vulnerability Assessment & Penetration Testing
RAF	Risk Acceptance Form
VA	Vulnerability Assessment
PT	Penetration Testing
ISC	Information Security Committee
SaaS	Software as a Service
PaaS	Platform as a Service
IaaS	Infrastructure as a Service

16. Review:

Vulnerability assessment & penetration SOP will be reviewed annually or whenever any changes happen.